PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité des données et bilan cybersécurité

01-55 CNIL - Guide de la sécurité des données personnelles et bilan cybersécurité 2025 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le pilotage de la sécurité nécessite d'impliquer la direction, de recenser les traitements et de tenir une revue de direction au moins annuelle.
2. La gestion des incidents impose une notification à la CNIL sous 72 heures, même si les informations ne sont pas encore complètes.
3. La protection des données en cloud ne repose pas uniquement sur le fournisseur.

Volume des notifications en 2025

6167
notifications de violations reçues par la CNIL

16
notifications par jour (près de)

Typologie et causes des violations

Nature / Cause	Part (%)
Perte de **confidentialité**	**94 %**
Pertes d'**intégrité** et de **disponibilité**	en progression (rançongiciels : **9 %** des notifications)
Piratage informatique	**la moitié** des notifications
Incidents chez des **sous-traitants**	**10 %**
Secteurs les plus touchés	Administration publique **19 %**, santé/action sociale **15 %**, finance/assurance **12 %**
Manquements fréquents (300+ contrôles/an)	Accès par **modification d'URL**, mots de passe faibles ou **en clair**, formulaires **HTTP**, pas de verrouillage de session ni de tests avant production

Pilotage, cadre et accès

Notion	À retenir
Piloter la sécurité	Direction impliquée ; traitements au registre ; flux formalisés ; plan d'action (responsables, échéances) ; contrôle d'effectivité ; **revue de direction annuelle**. Socle élémentaire + analyse de risques.
Cadre et formation	**Charte informatique** contraignante (ex. annexée au règlement intérieur) ; engagement de confidentialité ; charte administrateurs ; sensibilisation de tout nouvel arrivant.
Authentification	Identifiant **unique** ; mot de passe **80 bits** (12 car. de 4 types ou 14 sans spécial), **50 bits** si blocage après 10 échecs, **13 bits** sur matériel bloqué après 3 échecs ; empreinte **salée**.

Recommandations de sécurité informatique

Notion	À retenir
A. Postes, mobiles et réseau	Postes : **verrouillage automatique**, **pare-feu**, **antivirus**, **mises à jour**, **droits limités**, **exécution automatique désactivée**. Mobiles : **chiffrement**, **VPN**, **BYOD** évalué. Réseau : **WPA3/WPA2**, **VPN**, **SSH**, **DMZ**.
B. Serveurs, sites et développements	Serveurs : **services inutiles désactivés**, **TLS** (de préférence 1.3), **sauvegardes**. Sites : **HTTPS** (port **443**), **cookies HttpOnly/Secure**. Dev : **données fictives** en test, **pas de secret** en dépôt.
C. Locaux	Sécuriser par **portes verrouillées**, **alarmes testées**, **détection incendie**, **zones distinguées**, **visiteurs accompagnés** et **prises réseau protégées**.

Règles d'authentification et d'habilitation

Renouvellement Pas de renouvellement périodique imposé aux simples utilisateurs, mais **imposé aux administrateurs** ; gestionnaires de mots de passe encouragés ; jamais **MD5/SHA-1**.

MFA Recommandée pour **données sensibles**, **administration**, **accès distants** et **messagerie professionnelle** (privilégier **connaissance** et **possession**).

Habilitations Définies par **profils**, validées par un **responsable**, retirées au **changement de poste** ou **départ**, et revues au moins **une fois par an**.

Maîtrise des données et préparation aux incidents

Notion	À retenir
Échanges, sous-traitance et maintenance	Données chiffrées (**SFTP** ou **HTTPS**) avec canal de déchiffrement distinct. Sous-traitants : contrat **art. 28 RGPD**, audit, et hébergeur **HDS** pour santé. Maintenance : main courante, télémaintenance limitée, effacement sécurisé.
Traçabilité, sauvegardes et continuité	Journalisation (**6 mois à 1 an**) sans usage détourné. Sauvegardes : règle **3 2 1**, site distinct et **hors ligne**. Plan de continuité/reprise rédigé, testé et sans dégradation de la protection.
Gestion des incidents	Procédures d'alerte, critères de qualification, évaluation du risque. Registre interne et notification **CNIL** sous **72 heures** (possiblement en deux temps, sans attendre toutes les informations).

Sécurité par domaine technologique

Domaine	Mesures de sécurité et bonnes pratiques
Cloud	Sécurité **partagée** ; cartographier ; chiffrer au repos et en transit ; le chiffrement côté serveur **ne protège pas du fournisseur** ; **SecNumCloud** pour les données sensibles.
Applications mobiles	Minimiser les permissions ; chiffrer les communications en **TLS** ; protéger les secrets par les **coffres matériels** du téléphone.
Intelligence artificielle	Mobiliser une équipe pluridisciplinaire ; vérifier la qualité et l'intégrité des données (contre l'**empoisonnement**) ; documenter les limites.
API	Partager le strict nécessaire ; séparer administration et usage courant ; journaliser les échanges ; désactiver les anciennes versions non sûres.
Analyse de risques	Recenser les supports ; identifier pour les trois événements redoutés (**accès illégitime**, **modification non désirée** et **disparition**) les impacts, sources et menaces ; estimer gravité et vraisemblance (ex: **EBIOS Risk Manager**).
Cryptographie	Hachage **SHA-2/SHA-3** ; mots de passe **bcrypt, scrypt, Argon2, PBKDF2** ; **AES** ; **RSA ≥ 2 048 bits** ; jamais DES, 3DES, MD5, SHA-1.

Pièges et confusions

- ⚠ Confondre le hachage avec le chiffrement
- ⚠ Stocker une sauvegarde sur le même système que les données
- ⚠ Faire transiter des données personnelles ou des secrets dans une URL
- ⚠ Penser que la sécurité dans le cloud est la seule responsabilité du fournisseur

Sigles et définitions

RGPD	Règlement imposant des mesures techniques et organisationnelles pour garantir la sécurité des données
DPO	Délégué à la protection des données
AIPD	Analyse d'impact relative à la protection des données obligatoire pour les risques élevés
MFA	Authentification combinant au moins deux facteurs de catégories distinctes
DMZ	Zone démilitarisée séparant le réseau interne d'Internet par des passerelles
Shadow IT	Outils utilisés sans l'accord de l'organisme

Auto-test

1. Quel est le volume de notifications de violations reçues par la CNIL en 2025 ?
2. Quelle est la part des notifications liées à la perte de confidentialité ?
3. Combien de notifications sont reçues par jour en 2025 ?
4. Quelle est la part des incidents chez des sous-traitants ?
5. Quelle est la part des notifications liées aux rançongiciels ?

Réponses : **1.** 6167 · **2.** 94 % · **3.** près de 16 · **4.** 10 % · **5.** 9 %

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.